

**YOU'D BETTER SECURE YOUR
BLE DEVICES OR WE'LL KICK
YOUR BUTTS !**

 [@virtualabs](https://twitter.com/virtualabs) | DEF CON 26, Aug. 12th 2018

digital.security

WHO AM I ?

🔍 Head of R&D @ Econocom Digital Security

⚡ Studying **Bluetooth Low Energy** for 3 years

🛠 Developer & maintainer of **BtleJuice**

📱 Having fun with Nordic's **nRF51822** 😊

digital.security

AGENDA

BLE sniffing 101

Improving the BLE arsenal

- Sniffing BLE connections in 2018
- Introducing **BtleJack**, a flexible sniffing tool

BtleJacking: a brand new attack

- How it works
- Vulnerable devices & demos

BLE SNIFFING 101

digital.security

MUCH CHEAP TOOLS, (NOT) WOW RESULTS

- Sniffing existing/new connections with an **Ubertooth One**
- Sniffing new connections with an Adafruit's **Bluefruit LE Sniffer**
- Sniffing BLE packets with **gnuradio**

digital.security

UBERTOOTH ONE



- Sniffs existing and new connections
- Does **not** support *channel map updates*
- Costs \$120

digital.security

BLUEFRUIT LE SNIFFER

- Up-to-date software (Nov. 2017)
- **Proprietary** firmware from Nordic Semiconductor
- Sniffs only **new connections**
- Costs \$30 - \$40

digital.security



SOFTWARE DEFINED RADIO



- Sniffs **only** BLE advertisements
- Unable to **follow** any existing/new connection
- Latency
- Requires 2.4GHz compatible SDR device

BLE SNIFFING 101

BLE is designed to make sniffing difficult:

- 3 separate advertising channels
- Uses Frequency Hopping Spread Spectrum (FHSS)
- Master or slave can **renegotiate** some parameters at any time

Sniffing BLE connections is either hard or expensive

digital security

MAN IN THE MIDDLE



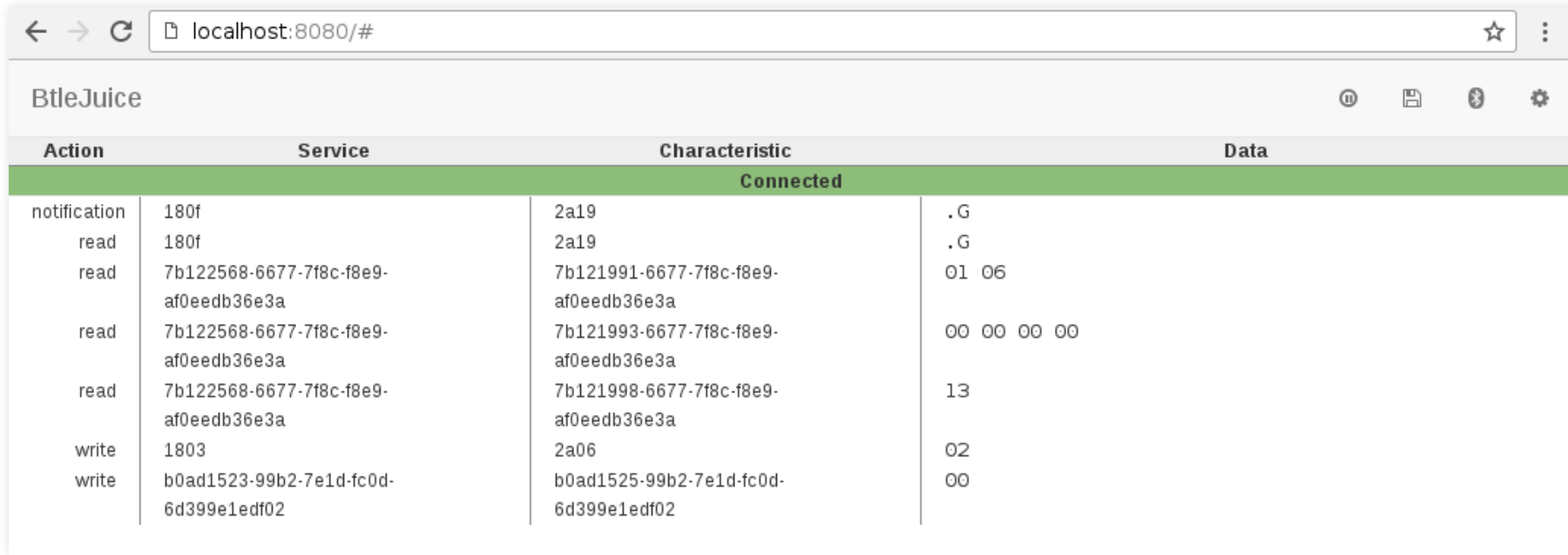
**"Watch where you're going, Larry — you walked
right through my wireless data stream!"**

digital.security

HOW BLE MITM WORKS

- Discover the target device (advertisement data, services & characteristics)
- Connect to this target device, it is not advertising anymore (connected state)
- Advertise the same device, await connections and forward data

BTLEJUICE



The screenshot shows the BtleJuice web application running in a browser at localhost:8080/#. The application has a header bar with the title 'BtleJuice' and several icons. Below the header is a table with four columns: Action, Service, Characteristic, and Data. A green bar with the text 'Connected' spans the width of the table. The table contains several rows of data representing Bluetooth LE actions and their results.

Action	Service	Characteristic	Data
Connected			
notification	180f	2a19	.G
read	180f	2a19	.G
read	7b122568-6677-7f8c-f8e9-af0eedb36e3a	7b121991-6677-7f8c-f8e9-af0eedb36e3a	01 06
read	7b122568-6677-7f8c-f8e9-af0eedb36e3a	7b121993-6677-7f8c-f8e9-af0eedb36e3a	00 00 00 00
read	7b122568-6677-7f8c-f8e9-af0eedb36e3a	7b121998-6677-7f8c-f8e9-af0eedb36e3a	13
write	1803	2a06	02
write	b0ad1523-99b2-7e1d-fc0d-6d399e1edf02	b0ad1525-99b2-7e1d-fc0d-6d399e1edf02	00

<https://github.com/DigitalSecurity/btlejuice>

digital.security

GATTACKER

[illegible]

<https://github.com/securing/gattacker>

digital.security

Pros:

- Get rid of the 3 advertising channels issue
- You see **every BLE operation** performed
- You may **tamper on-the-fly** the data sent or received

Cons:

- **Complex** to setup: 1 VM & 1 Host computer
- Only capture **HCI events**, not BLE Link Layer
- Does not support all types of **pairing**
- Only compatible with 4.0 adapters

WE ARE DOING IT WRONG !

- *Ubertooth-btle* is **outdated** and does not work with recent BLE stacks
- Nordic Semiconductor' sniffer is **closed source** and does not allow active connection sniffing and **may be discontinued**
- The MitM approach seems great but **too difficult** to use and does not intercept link-layer packets

IMPROVING THE BLE ARSENAL

digital.security

THE IDEAL TOOL

- Able to sniff existing and new connections
- Uses cheap hardware
- Open-source

digital.security

SNIFFING ACTIVE CONNECTIONS

digital.security

MIKE RYAN'S TECHNIQUE

LSB			MSB
Preamble (1 octet)	Access Address (4 octets)	PDU (2 to 257 octets)	CRC (3 octets)

1. Identify Access Address (32 bits)
2. Recover the *CRCInit* value used to compute CRC
3. $\text{hopInterval} = \text{time between two packets} / 37$
4. $\text{hopIncrement} = \text{LUT}[\text{time between channel 0 \& 1}]$

MIKE'S ASSUMPTION (2013)

All 37 data channels are used

DATA CHANNELS IN 2018

- Not all channels are used to improve reliability
- Some channels are *remapped* to keep a 37 channels hopping sequence

0, 4, 8, 12, 16, 20, 24, 0, 4, 8, 3, 7, 11, 15, 19, 23, 27, 3, 7,
2, 6, 10, 14, 18, 22, 26, 2, 6, 1, 5, 9, 13, 17, 21, 25, 1, 5

Mike's technique does not work anymore !

digital.security

HOW TO DEDUCE CHANNEL MAP AND HOP INTERVAL

- **Channel map**
 - Listen for packets on every possible channels
 - May take until 4×37 seconds to determine !
- **Hop interval**
 - Find a unique channel
 - Measure time between 2 packets and divide by 37

DEDUCE HOP INCREMENT

- Pick 2 unique channels
- Generate a lookup table
- Measure time between two packets on these channels
- Determine increment value

More details in **PoC||GTFO 0x17**

SNIFFING NEW CONNECTIONS

digital.security

CONNECT_REQ PDU

LLData									
AA (4 octets)	CRCInit (3 octets)	WinSize (1 octet)	WinOffset (2 octets)	Interval (2 octets)	Latency (2 octets)	Timeout (2 octets)	ChM (5 octets)	Hop (5 bits)	SCA (3 bits)

Figure 2.11: LLData field structure in CONNECT_REQ PDU's payload

- Every needed information are in this packet
- Sniffer must listen on the correct channel

"INSTANT" MATTERS

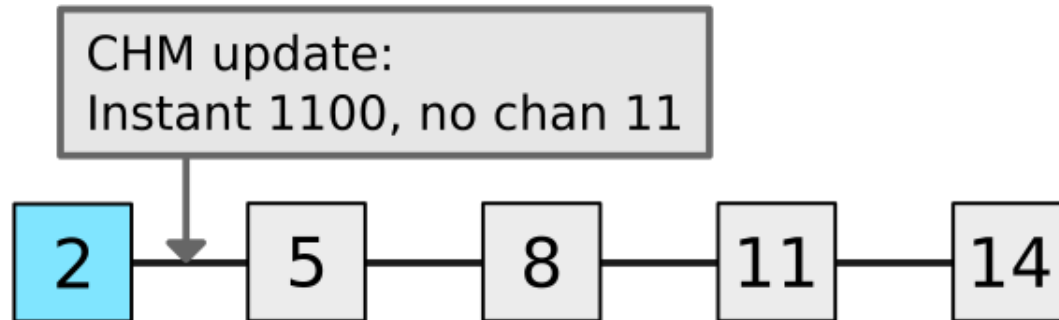
- Defines when a parameter update is effective
- Used for:
 - Channel map updates
 - Hop interval updates

WE DON'T CARE AT ALL



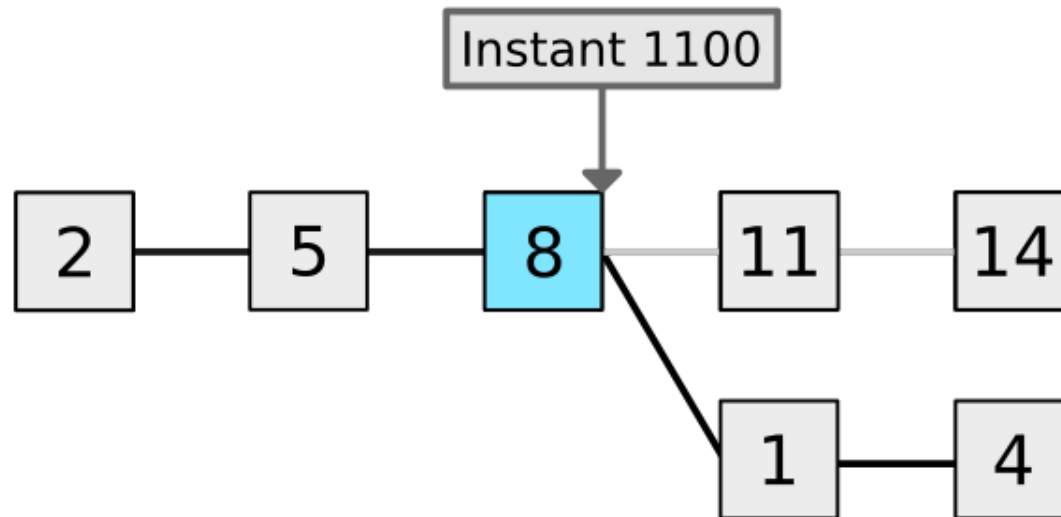
digital.security

WE DON'T CARE AT ALL



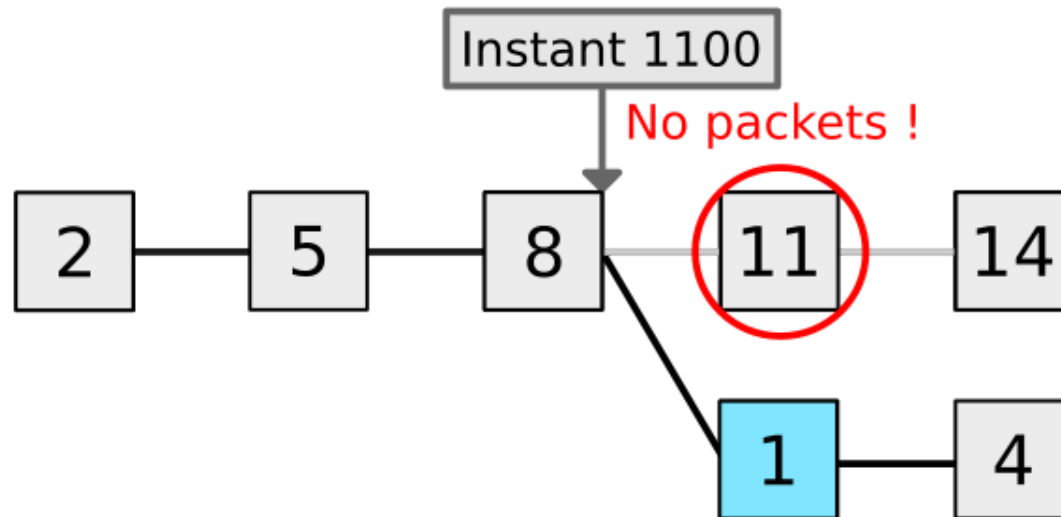
digital.security

WE DON'T CARE AT ALL



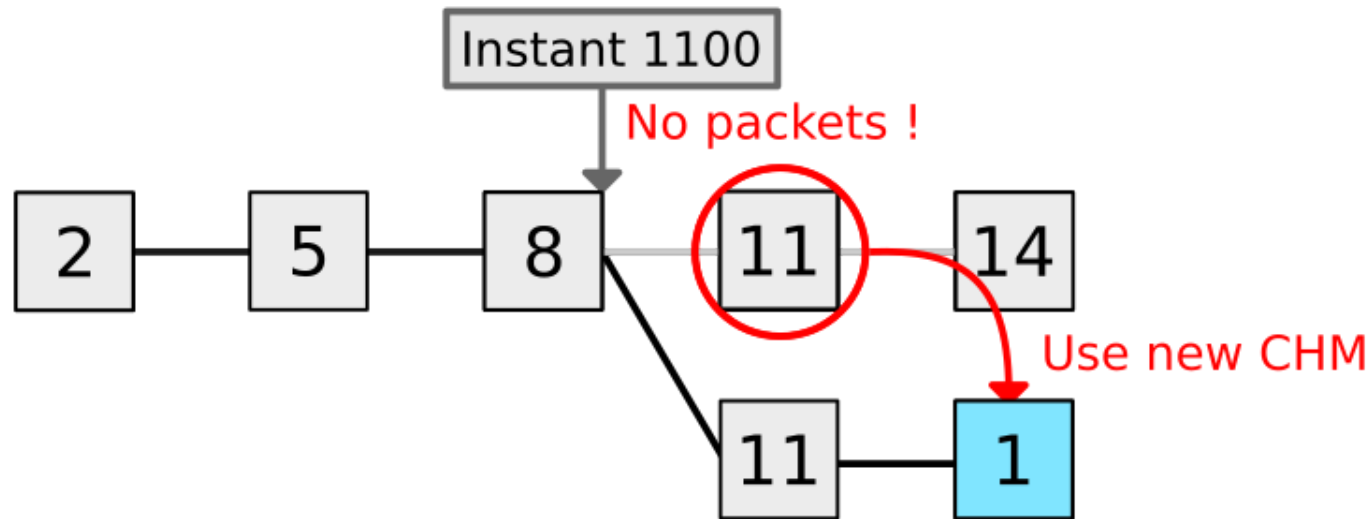
digital.security

WE DON'T CARE AT ALL



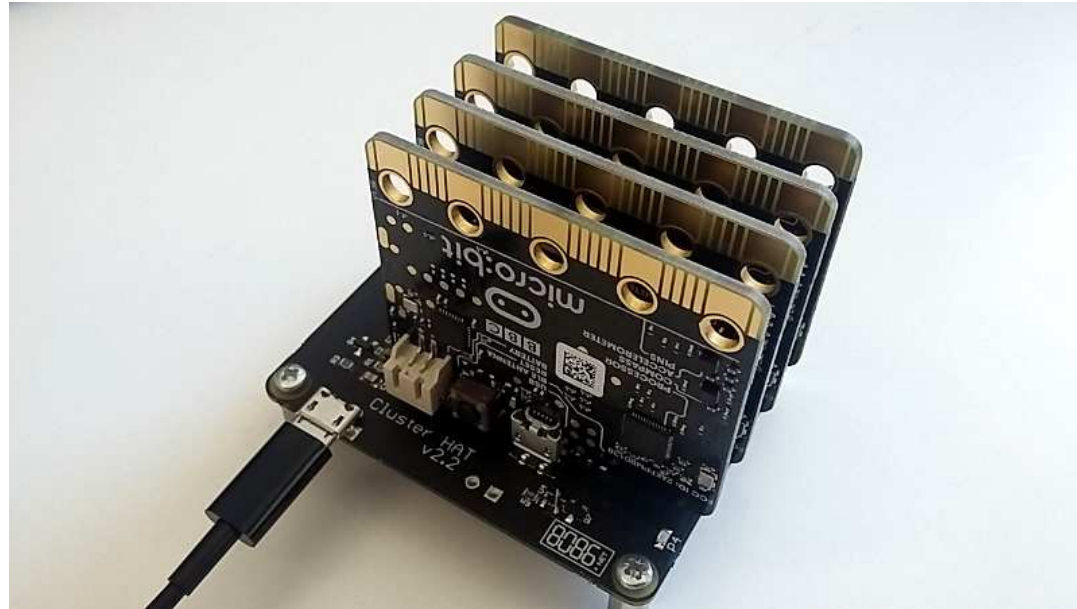
digital.security

WE DON'T CARE AT ALL



digital.security

MULTIPLE SNIFFERS FOR THE ULTIMATE SNIFFING TOOL

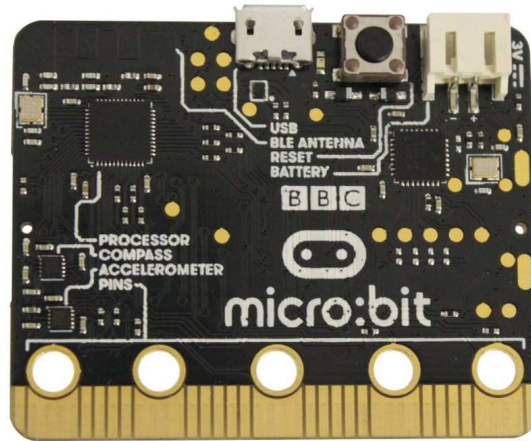


digital.security

A BRAND NEW TOOL ...

digital.security

... BASED ON A MICRO:BIT



\$15

digital.security

BTLEJUICE



digital.security

BTLE-JUICEJACK



digital.security

NO LIVE DEMO, I KNOW YOU.



digital.security

SNIFFING A NEW CONNECTION

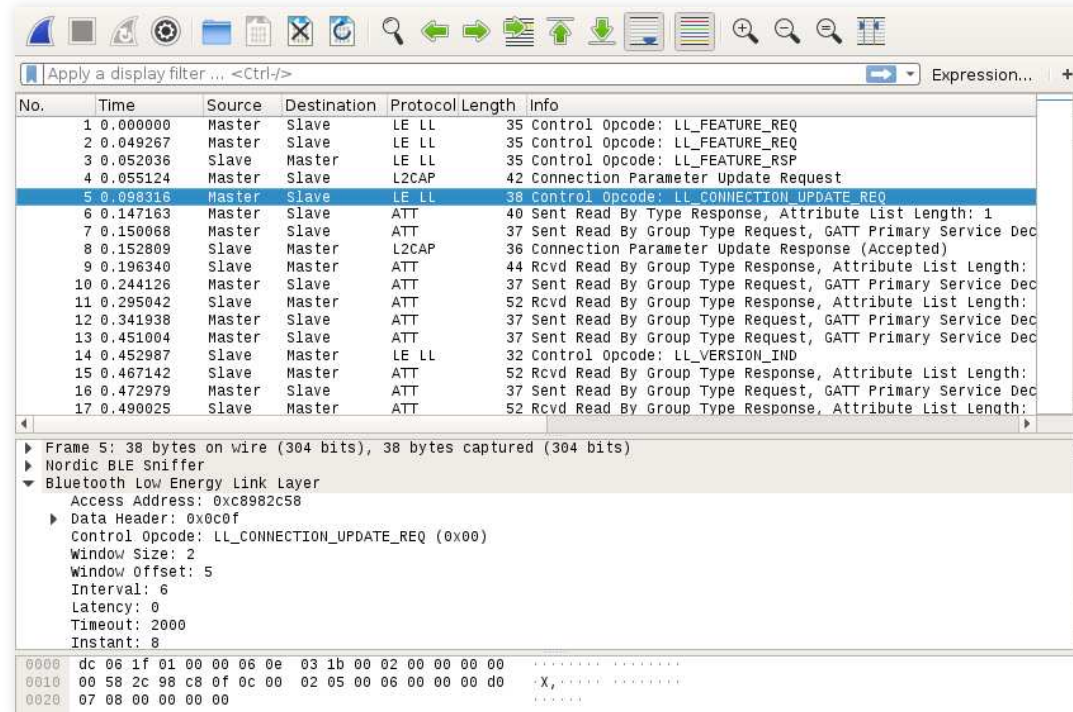
```
virtualabs@virtubox:~/demo$
```

SNIFFING AN EXISTING CONNECTION

```
virtualabs@virtubox:~/demo$
```

digital.security

PCAP EXPORT



The screenshot displays a network packet capture (PCAP) analysis tool interface. The top section shows a list of 17 packets with columns for No., Time, Source, Destination, Protocol, Length, and Info. Packet 5 is selected, showing a control opcode for LL_CONNECTION_UPDATE_REQ. The bottom section provides a detailed view of the selected packet, including the Access Address (0xc8982c58), Data Header (0x0c0f), and various Bluetooth Low Energy (BLE) parameters like Window Size, Window Offset, Interval, Latency, Timeout, and Instant. The packet data is also shown in hexadecimal and ASCII format.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	Master	Slave	LE LL	35	Control Opcode: LL_FEATURE_REQ
2	0.049267	Slave	Master	LE LL	35	Control Opcode: LL_FEATURE_REQ
3	0.052036	Slave	Master	LE LL	35	Control Opcode: LL_FEATURE_RSP
4	0.055124	Master	Slave	L2CAP	42	Connection Parameter Update Request
5	0.098316	Master	Slave	LE LL	38	Control Opcode: LL_CONNECTION_UPDATE_REQ
6	0.147163	Master	Slave	ATT	40	Sent Read By Type Response, Attribute List Length: 1
7	0.150068	Master	Slave	ATT	37	Sent Read By Group Type Request, GATT Primary Service Dec
8	0.152809	Slave	Master	L2CAP	36	Connection Parameter Update Response (Accepted)
9	0.196340	Slave	Master	ATT	44	Rcvd Read By Group Type Response, Attribute List Length:
10	0.244126	Master	Slave	ATT	37	Sent Read By Group Type Request, GATT Primary Service Dec
11	0.295042	Slave	Master	ATT	52	Rcvd Read By Group Type Response, Attribute List Length:
12	0.341938	Master	Slave	ATT	37	Sent Read By Group Type Request, GATT Primary Service Dec
13	0.451004	Master	Slave	ATT	37	Sent Read By Group Type Request, GATT Primary Service Dec
14	0.452987	Slave	Master	LE LL	32	Control Opcode: LL_VERSION_IND
15	0.467142	Slave	Master	ATT	52	Rcvd Read By Group Type Response, Attribute List Length:
16	0.472979	Master	Slave	ATT	37	Sent Read By Group Type Request, GATT Primary Service Dec
17	0.490025	Slave	Master	ATT	52	Rcvd Read By Group Type Response, Attribute List Length:

Frame 5: 38 bytes on wire (304 bits), 38 bytes captured (304 bits)
Nordic BLE Sniffer
Bluetooth Low Energy Link Layer
Access Address: 0xc8982c58
Data Header: 0x0c0f
Control Opcode: LL_CONNECTION_UPDATE_REQ (0x00)
Window Size: 2
Window Offset: 5
Interval: 6
Latency: 0
Timeout: 2000
Instant: 8

0000 dc 06 1f 01 00 00 06 0e 03 1b 00 02 00 00 00 00
0010 00 58 2c 98 c8 0f 0c 00 02 05 00 06 00 00 d0 ..X,
0020 07 08 00 00 00 00

Supports Nordic and legacy BTLE formats

digital.security

BTLEJACKING

A NEW ATTACK ON BLE

digital.security

SUPERVISION TIMEOUT

- Defined in CONNECT_REQ PDU
- Defines the time after which a **connection is considered lost** if no valid packets
- Enforced by both Central and Peripheral devices



digital.security

SUPERVISION TIMEOUT VS. JAMMING

Central



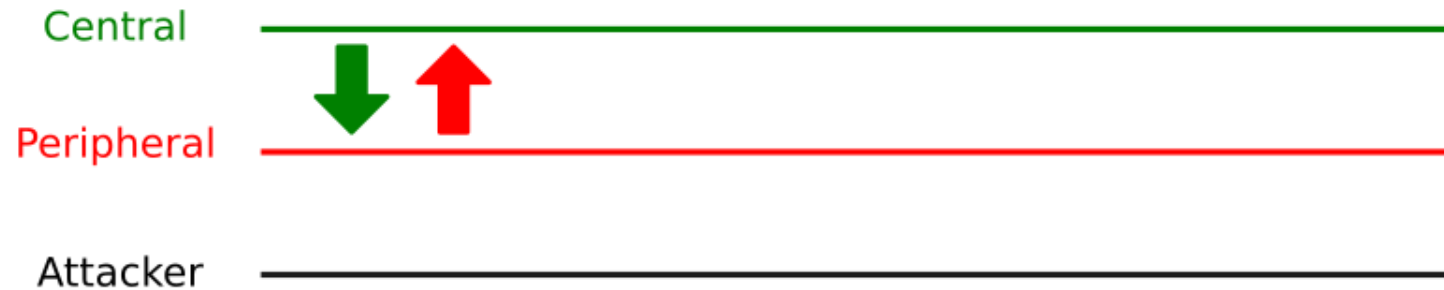
Peripheral



Attacker

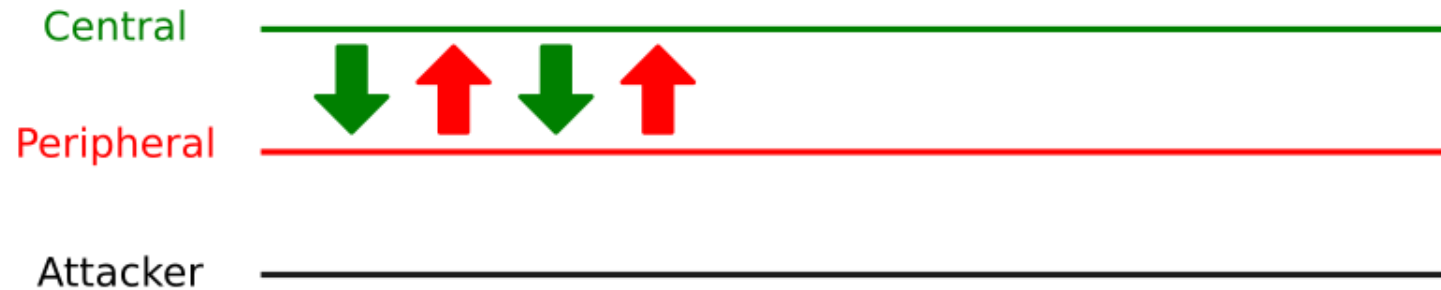


SUPERVISION TIMEOUT VS. JAMMING

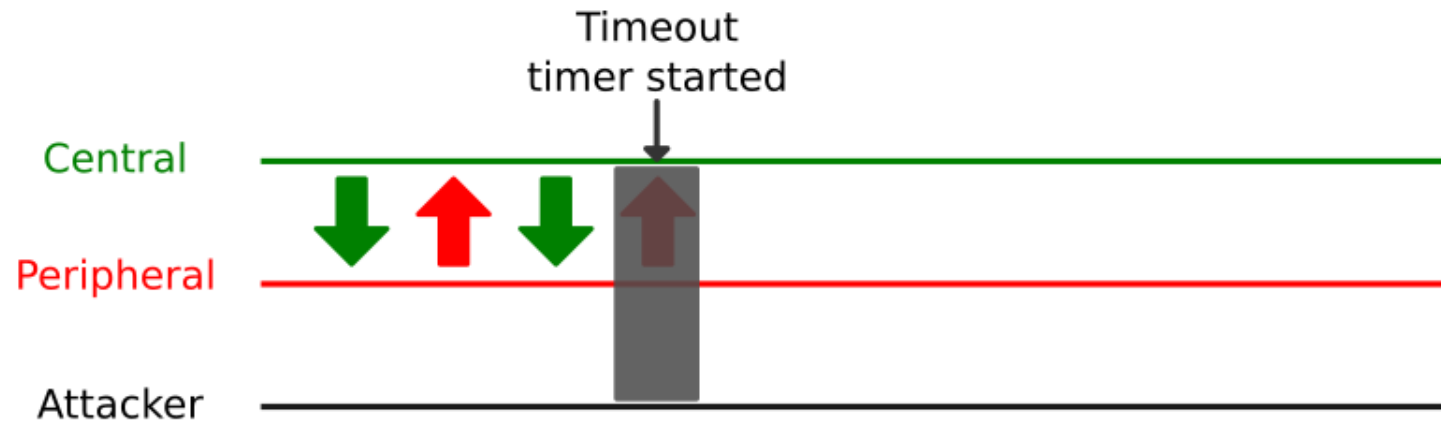


digital.security

SUPERVISION TIMEOUT VS. JAMMING

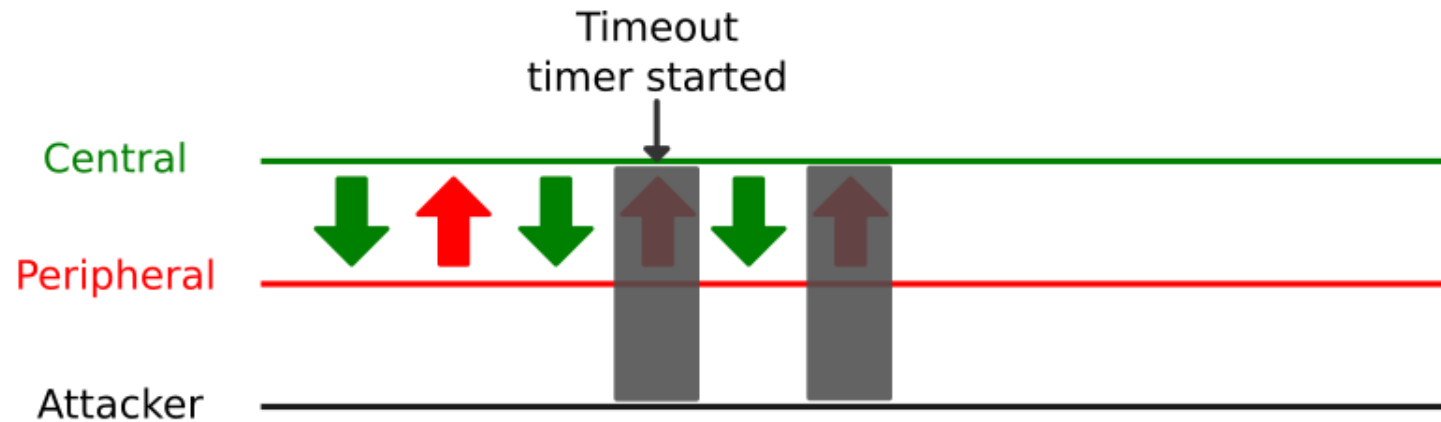


SUPERVISION TIMEOUT VS. JAMMING

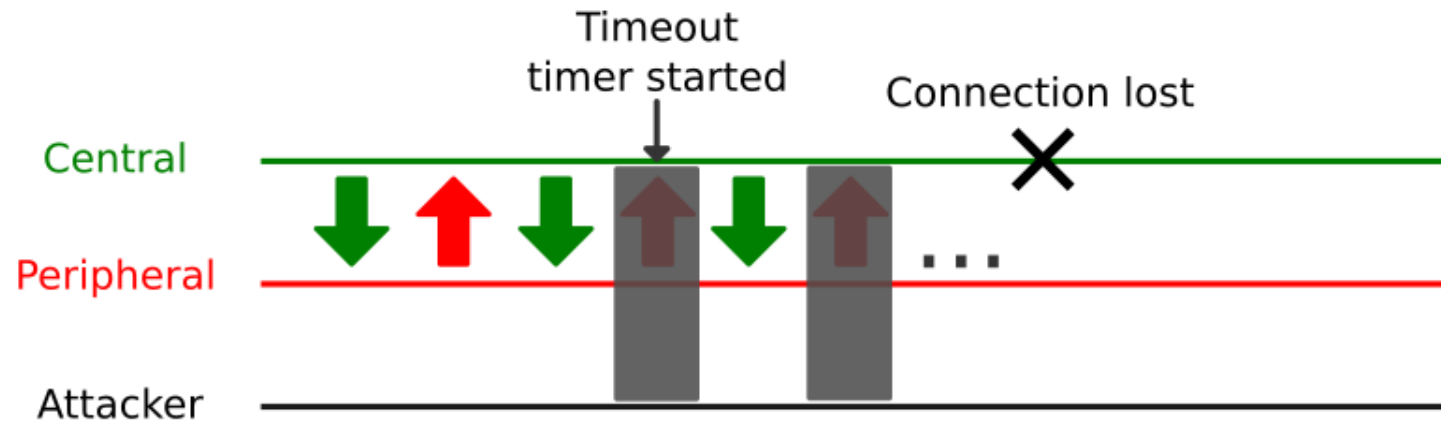


digital.security

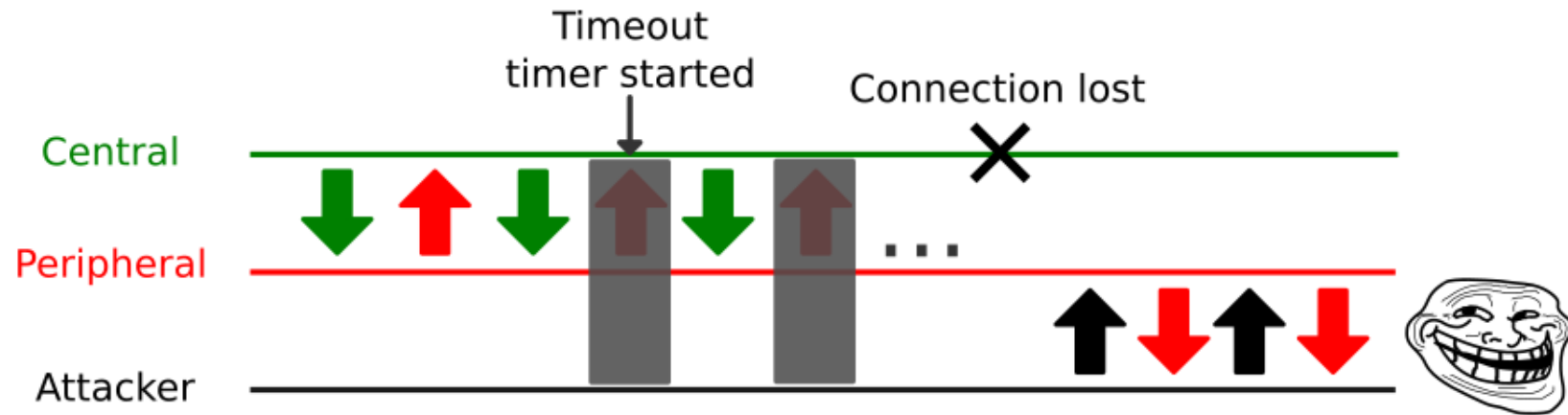
SUPERVISION TIMEOUT VS. JAMMING



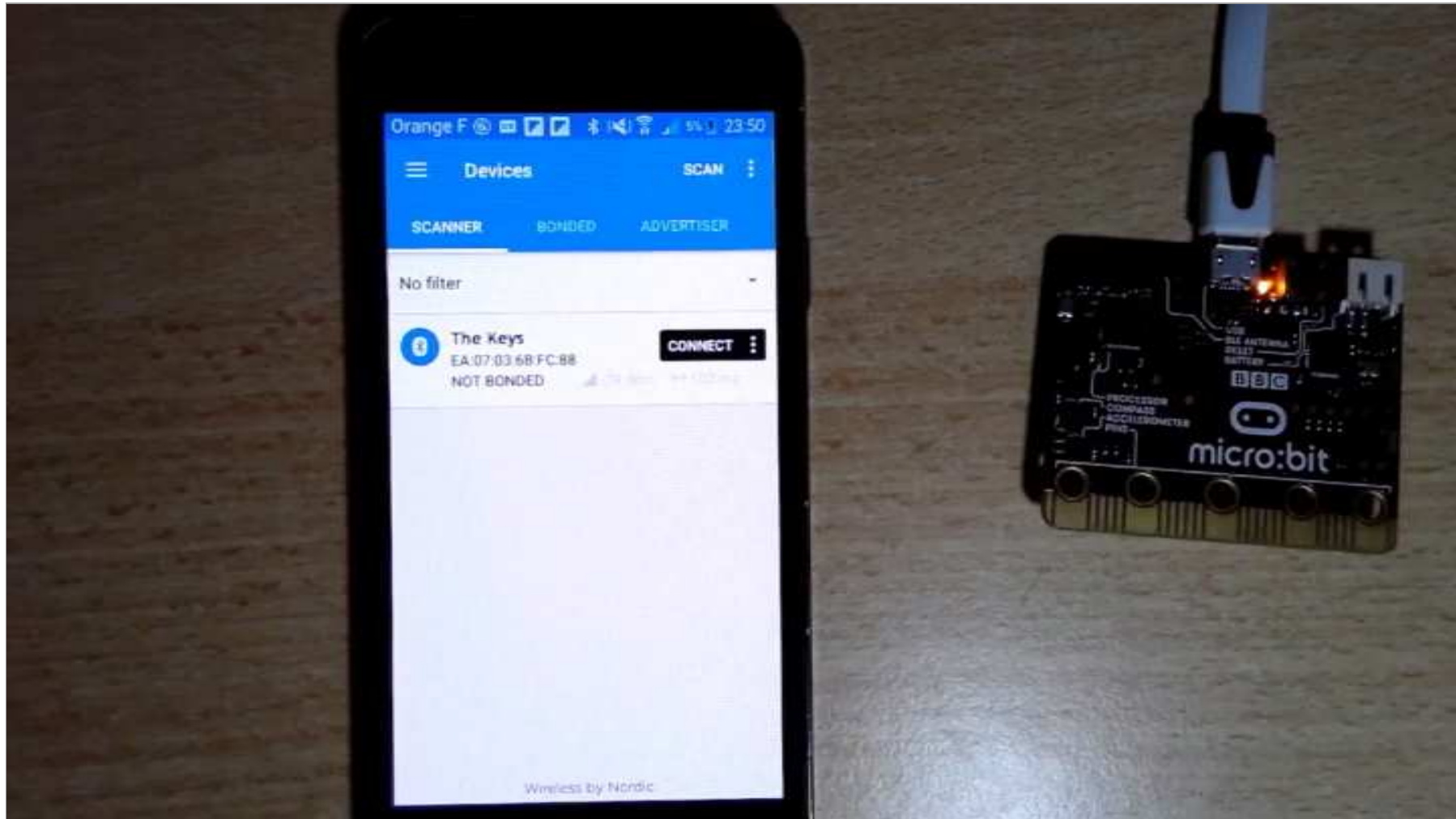
SUPERVISION TIMEOUT VS. JAMMING



SUPERVISION TIMEOUT VS. JAMMING



JAMMING FTW



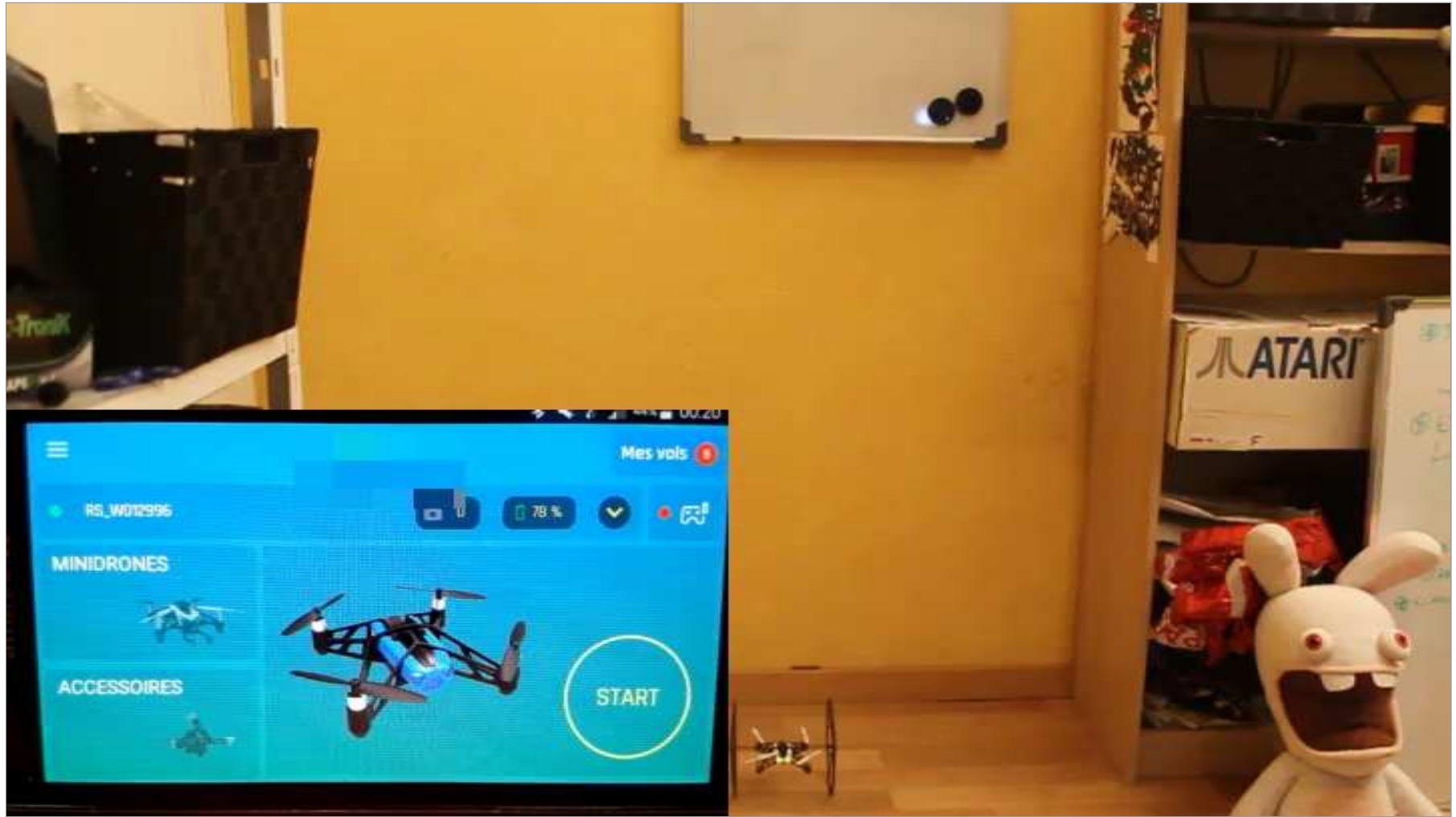
BTLEJACKING

- Abuse BLE supervision timeout to **take over a connection**
- BLE versions 4.0, 4.1, 4.2 and 5 are vulnerable
- **Requires proximity** (about 5 meters away from target)

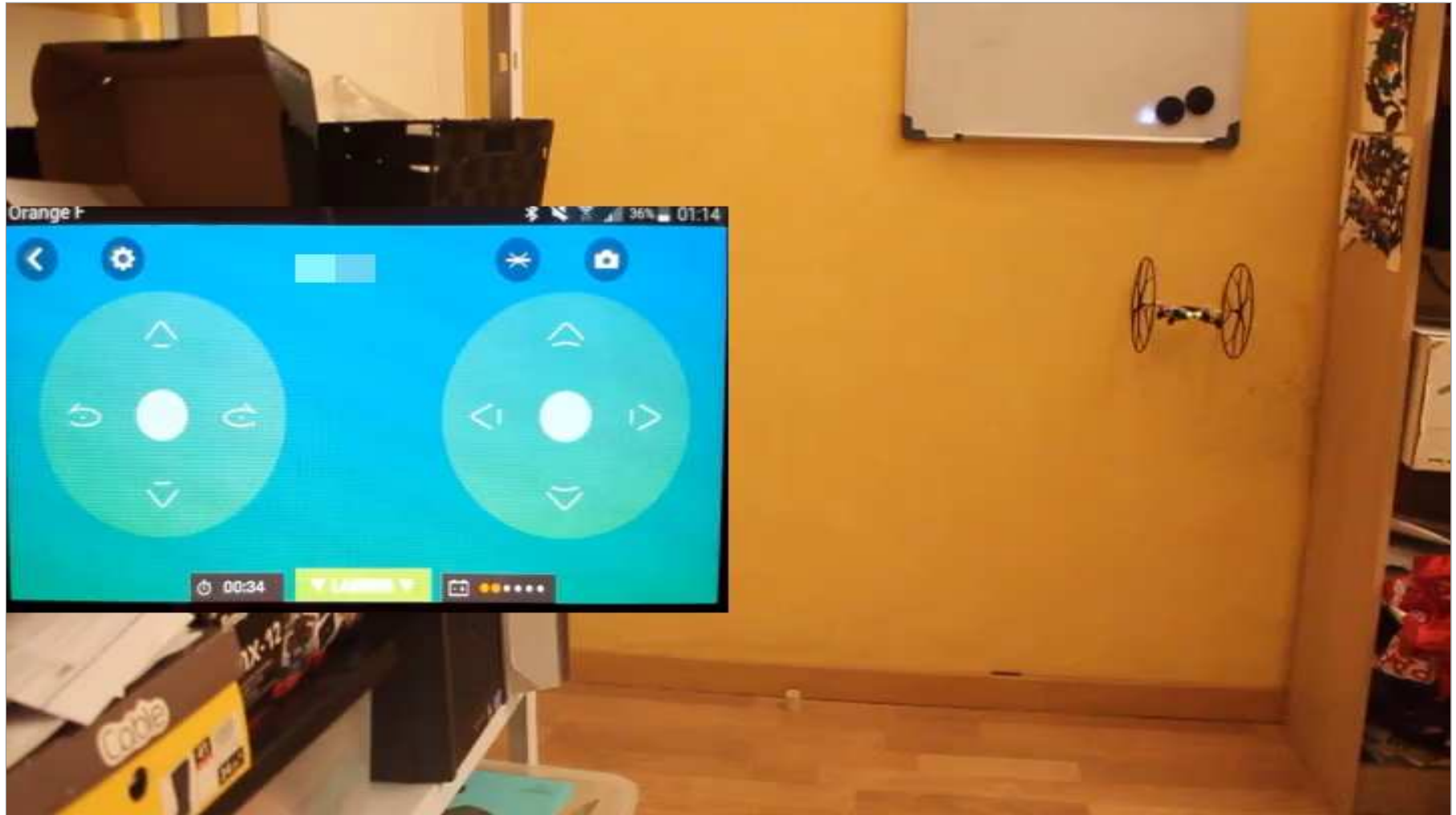
digital.security

EXAMPLE OF VULNERABLE DEVICES

digital.security



digital.security



digital.security

SEXTOYS TOO !

digital.security

So of course my colleagues suggested that my next project should be to reverse engineer it.

And here it is, the Lovense Hush:



SECURITY
Hacking Serial
Networks on
Ships
25 JUN 2018

REVERSE ENGINEERING
Hardware reverse
engineering. A
tale from the
workbench
22 JUN 2018

SERVICES
Automotive and
IoT Testing

#2. IF THE TOY IS ON AND CONNECTED, YOU'RE FINE

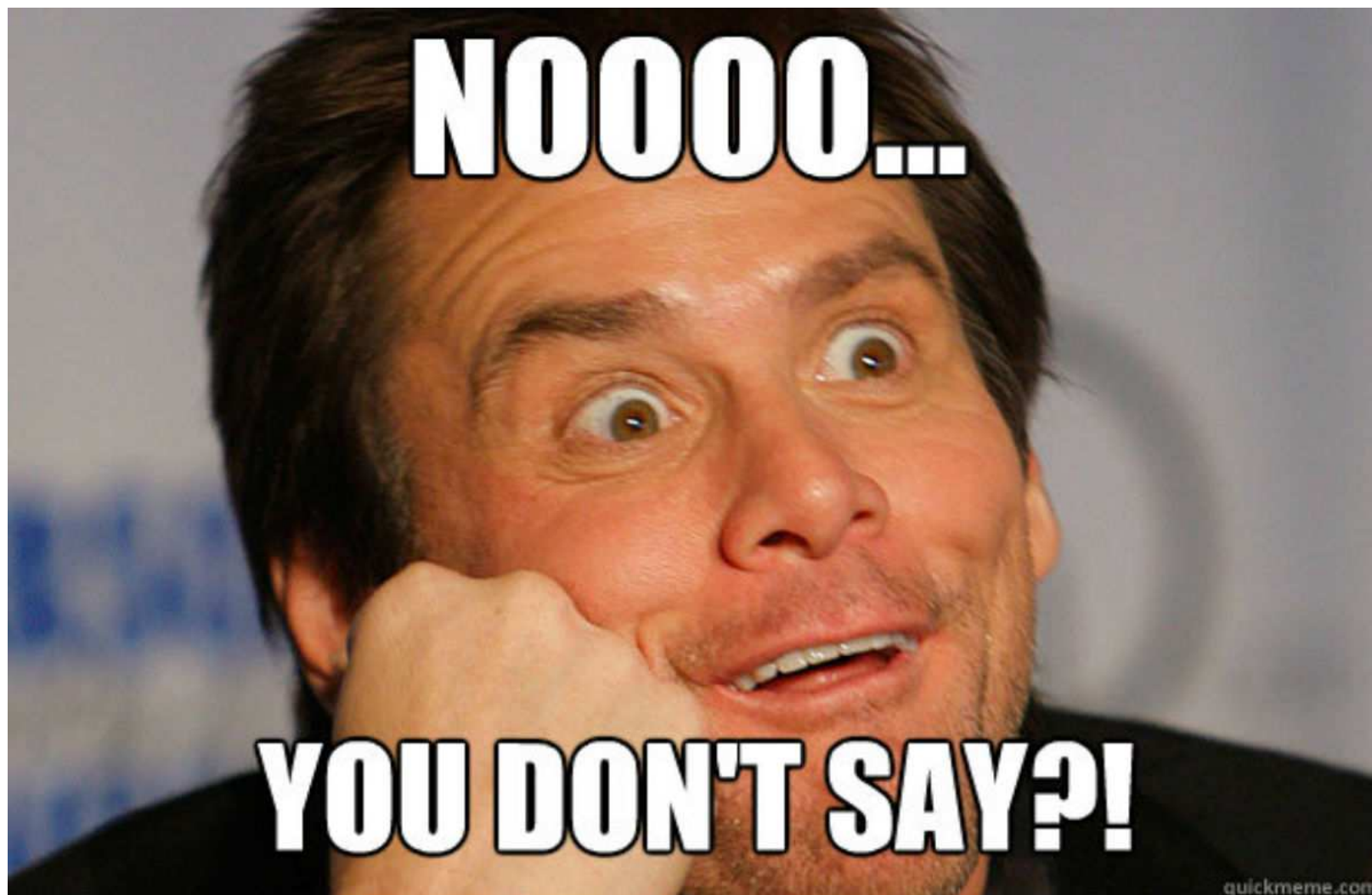
Hackers would need to walk/drive around the city hoping someone has a teledildonic toy that is on **but NOT connected** to any phone.

It's rare to encounter this situation because if a user is wearing it out of the house it needs to be connected to the app in order to function, and that's the entire purpose of wearing it outside.

And if it's on and connected to your phone, the hacking can't happen because it can only be controlled by one device at a time, aka the phone you're connected to.

<https://fr.lovense.com/sex-toy-blog/lovense-hack>

digital.security



digital.security



digital.security

IMPACT

- **Unauthorized access** to a device, even if it is already connected
- **Bypass authentication**, if authentication is performed at the start of connection
- Keep the device internal state intact: this may **leak valuable information**

digital.security

COUNTER-MEASURES

- Use **BLE Secure Connections** (see specifications)
- At least authenticate data at application layer

BTLEJACK

<https://github.com/virtualabs/btlejack>

digital.security

FEATURES

- Already established BLE connection sniffing
- New BLE connection sniffing
- Selective BLE jamming
- BLE connection take-over (btlejacking)
- PCAP export to view dumps in Wireshark
- Multiple sniffers support

CONCLUSION

- Btlejack is an **all-in-one** solution for BLE sniffing, jamming and hijacking
- BLE hijacking works on **all versions**
- Insecured BLE connections are prone to sniffing and hijacking
- It **might get worse** with further versions of BLE (greater range)
- **Secure your BLE connections FFS (really, do it)**

THANKS ! QUESTIONS ?

CONTACT



@virtualabs



damien.cauquil@digital.security

digital.security

WHY DIDN'T YOU IMPROVE *UBERTOOTH-BTLE* CODE ?

- I am a lot more familiar with nRF51 SoCs than LPC microcontrollers
- Buying 3 Ubertooth devices (\$360) is not “cheap”

HOW DID YOU MAKE YOUR CLUSTER ?

From a modified **ClusterHat v2** (\$30)

<https://shop.pimoroni.com/products/cluster-hat>

digital.security